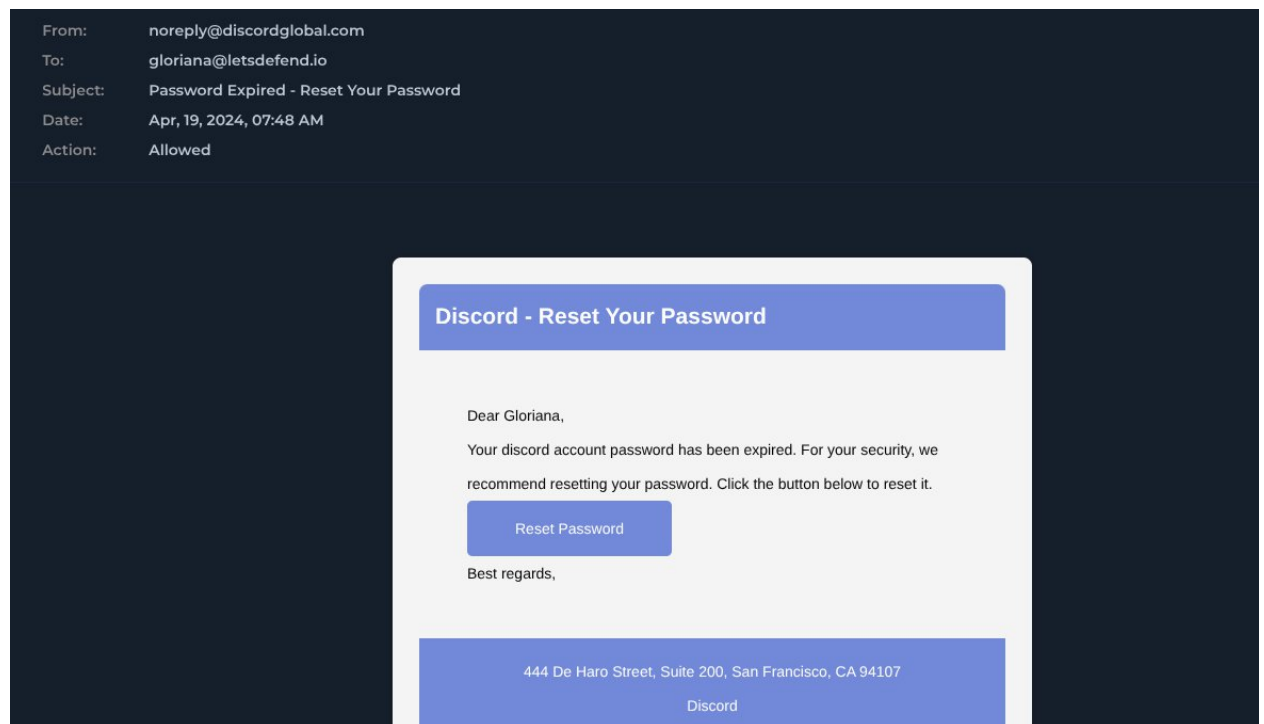


Event Information:

EventID :
250
Event Time :
Apr, 19, 2024, 08:23 AM
Rule :
SOC275 - Application Token Steal Attempt Detected
Level :
Security Analyst
Hostname :
Gloriana
IP Address :
172.16.17.172
Affected User :
gloriana@letsdefend.io
Trigger Request :
GET /reset-password?email=gloriana@letsdefend.io HTTP/1.1
Trigger Reason :
Detect potential application token theft attempts by monitoring web server access logs for GET or POST requests to password reset or account recovery pages, checking for the presence of HTTP request headers like 'Authorization' or 'Bearer', and targeting URLs associated with application tokens.
Device Action :
Redirect

Analysis Steps:

Email logs were searched to find what may have triggered this alert.



We can see a fake Discord password reset email which the user has engaged with.

Logs were searched with IP 172[.]16.17.172 (Gloriana) as the source in the relevant time-frame yielding 20 events.

Source Address contains "172.16.17.172"

✓ 20 events (before Apr, 20, 2024, 11:50 AM UTC)

Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

Event

type

source_address

source_port

destination_address

destination_port

time

Raw Log

Timestamp

Request

X-Forwarded-Host

X-Forwarded-Port

Proxy

172.16.17.172

49210

23.82.12.29

8081

Apr, 19, 2024, 08:23 AM

19/Apr/2024:08:23:46+0000

POST /reset-password?token=123letsdefendisthebest123 HTTP/1.1

homespottersf.com

8081

We can see how the attacker obtained the user's access token.

Gloriana's account tokens/passwords will need to be immediately revoked and reset.

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. The attacker utilised legitimate web hosting infrastructure so the IP does not reveal much useful information. The domain is also no longer online.

0 / 91

Community Score

10+ detected files communicating with this IP address

23.82.12.29 (23.82.8.0/21)

AS 30633 (Leasoweb USA, Inc.)

US

Last Analysis Date

13 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 129

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

alphaMountain.ai	Suspicious	Abusix	Clean
Acronis	Clean	ADMINUSLabs	Clean
ALabs (MONITORAPP)	Clean	AlienVault	Clean
Anty-AVL	Clean	BitDefender	Clean

1 / 91

Community Score

1/91 security vendor flagged this domain as malicious

homespottersf.com

Registrar

DropCatch.com 957 LLC

Creation Date

2 years ago

Last Analysis Date

16 hours ago

DETECTION

DETAILS

RELATIONS

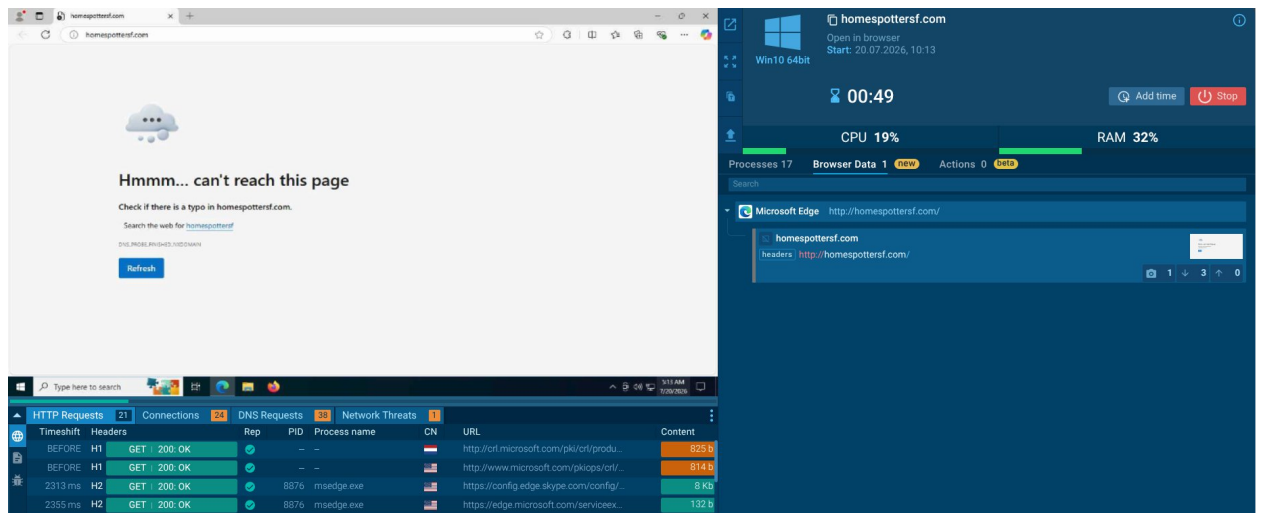
COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

ADMINUSLabs	Malicious	Gridinsoft	Suspicious
Abusix	Clean	Acronis	Clean
ALabs (MONITORAPP)	Clean	AlienVault	Clean
alphaMountain.ai	Clean	Anty-AVL	Clean



Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary Analysis confirms a True Positive application token theft resulting from a successful phishing campaign. An external threat actor delivered a spoofed Discord notification email to an internal user. The user interacted with the malicious link, ultimately resulting in the exfiltration of an active application token to an attacker-controlled web server.

Incident Details

- **Alert Name:** SOC275 - Application Token Steal Attempt Detected
- **Target Account:** gloriانا[@]letsdefend[.]io
- **Target Host:** Gloriana (172[.]16.17.172)
- **Device Action:** Redirect

Analysis and Evidence

- **Delivery Vector:** The attacker sent a deceptive email originating from noreply[@]discordglobal[.]com with the subject "Password Expired - Reset Your Password". The device action was "Allowed," meaning it successfully reached the user's inbox.
- **Initial Interaction:** The user clicked the embedded link at 08:23 AM, triggering the initial alert via a GET request to /reset-password?email=gloriana[@]letsdefend[.]io.
- **Data Exfiltration:** Proxy logs at 08:23:46 AM reveal a subsequent outbound POST request from 172[.]16.17.172 to the attacker's domain, homespottersf[.]com (23[.]82.12.29), over port 8081.
- **Compromise Confirmation:** The POST request successfully transmitted the payload: ?token=123letsdefendisthebest123. The attacker's server responded with HTTP Status 200 (OK), confirming the stolen token was received.

Threat Intelligence

- **Infrastructure OSINT:** The malicious domain homespottersf[.]com and IP 23[.]82.12.29 are external to the organisation. While the attacker utilised legitimate web hosting infrastructure, the environment was explicitly used for credential harvesting.
- **Domain Status:** Dynamic analysis confirms the phishing domain homespottersf[.]com is currently offline and unreachable.

Actions Taken

1. Analysed email logs to identify the spoofed sender address and the phishing lure used to trick the user.
2. Searched proxy telemetry for the affected host (172[.]16.17.172), locating when the application token was transmitted.
3. Deleted the email from the user's inbox.
4. Isolated the device from the network.
5. Declared the alert as a True Positive and escalated.

Let's Defend Result

SOC275 - Application Token Steal Attempt Detected

True Positive (+5 Point)

Has Anyone Accessed IP/URL/Domain? (+5 Point)

Analyze URL Address (+5 Point)